

A Certified Cyber Range for Automated Defenders: Provable Residual-Risk Scores Against an Adaptive Adversary

Anonymous Author(s)
Anonymized for double-blind review

Abstract—Autonomous cyber defenders are judged almost entirely by *empirical* outcomes (attack-success rates, flags captured), which say nothing provable about the residual risk a defender leaves, least of all against an attacker that adapts. This work-in-progress describes a small cyber range that scores defenders with a *provable* verdict instead. Built on the real MITRE ATT&CK Enterprise kill chain (v17.1, 44 mitigations) and a hospital-ransomware impact model, it returns for any control portfolio a distribution-free *guaranteed/possible* certificate that the worst-case probability of at least k clinical services in simultaneous sustained outage stays below ε , over all failure-dependence structures and every parameter in an interval uncertainty set. Defenders are scored against a *typical* adversary and an *adaptive* one that best-responds by routing through the most open technique at each stage. The provable score exposes what an empirical one cannot: 10 of 12 adaptive regimes admit no certifying portfolio at any cost. Using the certificate as feedback cuts a certificate-blind heuristic’s control burden by about a third against the typical adversary, yet the same greedy defender can fall far short of the exact optimum against the adaptive one. The defender interface is agent-agnostic, so learning and LLM-based defenders can be held to the same guarantee.

Index Terms—autonomous cyber defense, evaluation environments, cyber range, certification, MITRE ATT&CK, adaptive adversary

1. Introduction

Autonomous defense agents are trained and compared in simulated networks [1], and language-model agents now automate offensive steps [2]. Their scores are sampled outcomes. Two defenders with the same attack-success rate can leave very different worst-case risk, and a sampled score cannot say that *no* defense would meet a target. We describe a range whose score is a certificate instead, built on ATT&CK [3] and on public data about patient harm during hospital cyberattacks [4]. **Contributions:** (i) an environment whose score is a distribution-free guaranteed/possible certificate for k -of- n clinical outage; (ii) a closed-form adaptive adversary that makes the range dynamic while keeping the certificate exact; (iii) a benchmark of four reference defenders across 48 regimes, including their optimality gap against an exact optimiser.

2. The range

A defender chooses a *control portfolio*: a set of ATT&CK mitigations (M####). Via the real mitigates edges, each mitigation lowers the success probability of the techniques it covers, and the kill-chain reachability to the ransomware impact objective composes those into a per-clinical-service sustained- outage probability. The range’s *score* is the certificate, not a sampled outcome: worst- and best-corner evaluation over the interval uncertainty set gives a *guaranteed* verdict (adequate even at the adverse corner) and a *possible* one; the catastrophic k -of- n event uses the sharp Fréchet-type bound on the probability that at least k of n dependent events occur [5], so the verdict holds whatever the true correlation between service failures. The observation (named mitigations, techniques covered, stages touched), the action (add/remove a mitigation), and the certified score form an agent-agnostic API.

3. Two adversaries

The certificate’s default reachability is a *typical* adversary: each kill-chain stage succeeds with the usage-weighted mean residual over its techniques. We add an *adaptive* adversary that best-responds to the current defense—stage success is the *maximum* residual over the stage’s techniques, i.e. the attacker routes through whatever the defender left most open. This is the closed-form best response (no iteration): as the defender covers the easiest path, the adversary’s maximum shifts to the next. Adaptive reachability dominates the typical one pointwise, so the adaptive certificate is a strictly stronger guarantee, and it stays monotone, so the interval-corner certificate is still exact. Scoring defenders against it makes the range genuinely *dynamic*.

4. Reference defenders and regimes

We score four automated (non-LLM) defenders: an *exact* minimum-cost optimiser (budget-bounded search, feasible because adequacy is monotone in the portfolio); a *greedy* defender adding the mitigation with the largest worst-case reachability reduction (certificate-guided); a *coverage* heuristic maximising techniques covered while ignoring the certificate; and a seeded *random* policy. Each is scored across 48 regimes: both adversaries $\times$ assumed vs. real CIPHER-derived degradation $\times$ adequacy levels $\varepsilon \in \{0.10, 0.05, 0.01\}$

TABLE 1. REFERENCE DEFENDERS BY MEAN COST-TO-CERTIFY (OVER THE REGIMES THEY COULD CERTIFY), UNDER THE TYPICAL AND THE ADAPTIVE ADVERSARY, WITH THE FRACTION OF ALL 48 REGIMES CERTIFIED.

Defender	Certified (%)	Mean (typical)	Mean (adaptive)
Optimal (exact)	50	1.6	2.0
Greedy (certificate)	62	2.6	17.3
Coverage (blind)	62	4.1	15.3
Random	62	10.4	20.3

$\times$ catastrophic thresholds $k = 1.4$. The metric is *cost-to-certify*: the smallest portfolio a defender reaches that the range certifies as adequate, or “none” when no portfolio does.

5. Results

Under the typical adversary, using the certificate as feedback cuts the control burden by about a third: the greedy defender averages 2.6 controls against 4.1 for the certificate-blind coverage heuristic, close to the exact optimum’s 1.6 (Table 1). The adaptive adversary changes the picture sharply. It is undefendable in most regimes: 10 of the 12 adaptive regimes (assumed degradation) admit *no* certifying portfolio at any cost (Table 2), because some techniques carry no ATT&CK mitigation and the worst-case attacker always routes through them. Where certification *is* possible ($\varepsilon = 0.10$, $k = 3$), the certificate-guided greedy defender needs 26 controls against the adaptive adversary while the exact optimum needs 4—so a defender tuned to the reachability objective can be far from the catastrophic optimum, and only a provable score reveals either the gap or, more importantly, that no portfolio suffices. Indeed, averaged over the adaptive regimes it can certify, greedy (17.3 controls) costs *more* than the certificate-blind coverage heuristic (15.3; Table 1): a reachability-tuned ordering can actively mislead against an adaptive adversary. An empirical attack-success benchmark would report a low sampled failure rate for the same portfolios and hide all of this.

6. Why the adaptive adversary is undefendable

Adaptive reachability is monotone in the portfolio, so deploying every mitigation attains its minimum. A stage containing a technique that ATT&CK maps to no mitigation keeps that technique at the base rate whatever is deployed, which floors the fully-defended catastrophic bound at 23.0% for $k=1$ and 5.1% for $k=4$ in v17.1 (Figure 1, right). Certification is possible only where that floor lies below ε , and no effectiveness prior changes this: even the most optimistic leaves 7 of 12 adaptive regimes uncertifiable. A concurrent submission [6] measures these gaps across seven years of ATT&CK releases; here the point is only that a provable score surfaces them.

TABLE 2. COST-TO-CERTIFY PER REGIME UNDER THE ADAPTIVE ADVERSARY (ASSUMED DEGRADATION). “NONE” MEANS NO PORTFOLIO CERTIFIES AT ANY COST; “>4” MEANS THE EXACT OPTIMUM EXCEEDS THE SEARCH CAP.

ε	k	Optimal	Greedy	Coverage	Random
0.10	1	none	none	none	none
0.10	2	none	none	none	none
0.10	3	4	26	26	33
0.10	4	0	0	0	0
0.05	1	none	none	none	none
0.05	2	none	none	none	none
0.05	3	none	none	none	none
0.05	4	none	none	none	none
0.01	1	none	none	none	none
0.01	2	none	none	none	none
0.01	3	none	none	none	none
0.01	4	none	none	none	none

7. A language-model defender

To test the interface with an actual language-model agent, we run an open-weight model locally (served by Ollama, no external API) as a defender. Each turn it sees the regime (adversary, k , ε), the catalog of mitigations with the techniques and stages each covers, what it has deployed, and the certified worst-case bound; it replies with one JSON action (add, remove, or stop). It is told to reach the target with as few mitigations as possible and to stop if it judges the target unreachable; the reachability floor is not revealed. Invalid replies are no-ops and are counted. The protocol was fixed before any model was run: 4 typical and 4 adaptive regimes (assumed degradation), the adaptive ones one certifiable ($\varepsilon=0.10$, $k=3$) and three that no portfolio can certify; 3 seeds each at temperature 0.7 (24 episodes); at most 30 turns; a 16384-token context. The metrics are the share of episodes certified, the cost at first certification against the exact optimum and the greedy defender, whether the agent stops on uncertifiable regimes rather than deploying until the turn limit, and the rate of invalid actions. Replaying the greedy defender through the same text interface reproduces its benchmark costs exactly, which checks the harness.

8. Roadmap

The next step is the one this draft does not yet take: evaluating learning and language-model defenders. The interface already exposes a textual observation (named mitigations, techniques covered, stages touched) and a discrete action space, so an LLM agent can act through it without changes to the scorer. We plan to report each agent’s certified risk as a multiple of the fully-defended floor, which separates what an agent failed to do from what ATT&CK does not allow; to add adversaries that learn rather than best-respond in closed form; and to add further impact models beyond the hospital.

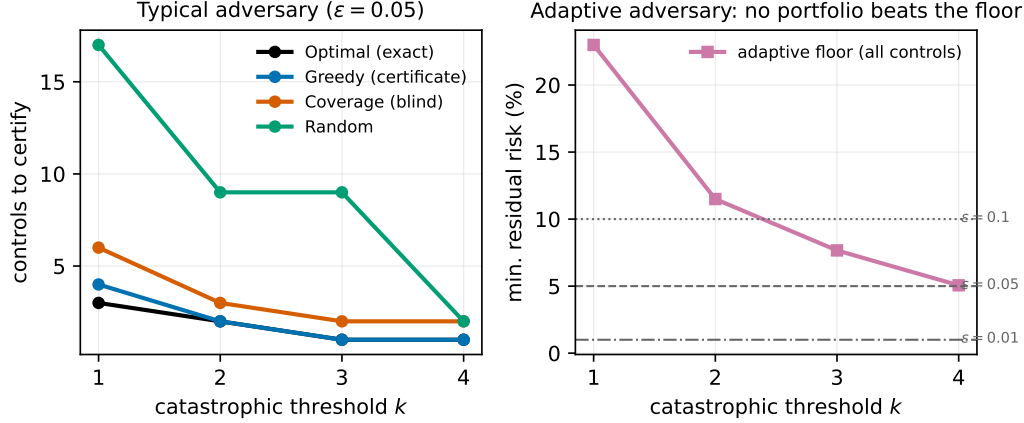


Figure 1. Left: under the typical adversary, cost-to-certify falls with k and the certificate-guided greedy defender tracks the exact optimum while the blind heuristics lag. Right: under the adaptive adversary, the reachability floor (all controls deployed) sits above ϵ for small k , so no portfolio certifies there.

9. Scope and limitations

To our knowledge this is the first to score automated defenders with a *distribution-free, provable* residual-risk certificate rather than an empirical outcome; ATT&CK-based defender-policy evaluation and optimisation-based control selection that minimises residual risk are established lines of work, and what is ownable here is the provable score and the adaptive-adversary reachability floor it exposes, not the idea of scoring defenders on ATT&CK. It is realistically a work-in-progress contribution—not a new theorem (interval-corner certificates and the k -of- n bound are standard) and not a validated real-world defense. Most pointedly for an agentic-defense venue, the defenders evaluated here are classical search procedures, not autonomous agents: the contribution is the evaluation environment and the guarantee it enforces, and the agent-agnostic API is the intended bridge, but no agentic defender is evaluated in this draft. MITRE ATT&CK and the CIPHER harm corpus are real; the hospital is synthetic, since real hospital maps and per-incident telemetry are not public. Effectiveness and degradation are analyst-prior intervals anchored to published figures, never incident measurements, and the certificate verdicts are conditional worst-case frequencies under those intervals, not statistical confidence levels. The adaptive adversary is a worst-case routing model, not a learned attacker; that it renders many regimes undefendable is a statement about ATT&CK mitigation *coverage* under a worst-case assumption, not a claim that real defense is hopeless. The reference defenders are deliberately simple automated policies. The value of the range is that its score is a *provable* residual-risk bound—holding even against an adversary that adapts, and able to say “no portfolio suffices”—rather than an average, and that an agentic defender can be dropped into the same API and held to the same guarantee.

Reproducibility and AI use. All numbers are generated from committed tables; the benchmark is deterministic (a single fixed seed for the random policy) and carries a

provenance manifest recording the SHA-256 of every input and output over the pinned ATT&CK bundle and the CIPHER corpus. No LLM or network access is used by the range or the defenders. Code and data will be released on publication. The code and draft text were produced with the assistance of an AI system (Claude); all results are reproduced by automated tests.

References

- [1] M. Standen, M. Lucas, D. Bowman, T. J. Richer, J. Kim, and D. Marriott. CybORG: A gym for the development of autonomous cyber agents. arXiv:2108.09118, 2021.
- [2] G. Deng, Y. Liu, V. Mayoral-Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, and S. Rass. PentestGPT: Evaluating and harnessing large language models for automated penetration testing. In *USENIX Security Symposium*, 2024.
- [3] B. E. Strom et al. MITRE ATT&CK: Design and Philosophy. MITRE Technical Report, 2018 (revised 2020).
- [4] I. Straw. CIPHER dataset v1: Patient harms during hospital cyberattacks (v1.0.0). The CIPHER Platform, 2025. Data set, CC BY 4.0.
- [5] L. Rüschendorf. Bounds for distributions with multivariate marginals. In *Stochastic Orders and Decision under Risk*, IMS Lecture Notes, 1991.
- [6] Anonymous. Uncoverable by design: The ceiling that seven years of MITRE ATT&CK mitigation gaps place on autonomous cyber defense. Concurrent submission to AIDC 2026.